vulnerability assessment report
task-1

By K.EVANGELIN JACINTH PAUL

Target Website: testphp.vulnweb.com

Assessment Type: Passive & Manual Security Testing

Tools Used:

- Nmap
- OWASP ZAP (Passive Scan)
- Browser Developer Tools

EXECUTIVE SUMMARY

- A vulnerability assessment was conducted on the target website to identify security weaknesses in server configuration, communication security, cookies, and exposed technologies.
- The assessment identified multiple high and medium-risk vulnerabilities, including:
- Absence of HTTPS encryption
- Use of outdated PHP version
- Server information disclosure
- Insecure cookie configuration
- Missing security headers
- Overall Risk Rating: HIGH
- Immediate remediation is recommended

SCOPE OF ASSESSMENT

- target: testphp.vulnweb.com
- Testing Type: Non-intrusive / Passive
- No exploitation performed
- Only publicly accessible resources analyzed

METHODOLOGY

The assessment followed these steps:

1. Reconnaissance using Nmap
2. Header analysis using Browser DevTools
3. Security tab inspection
4. Cookie inspection
5. Response header analysis
6. Manual verification of security configurations

RECONNAISSANCE USING NMAP

install Nmap

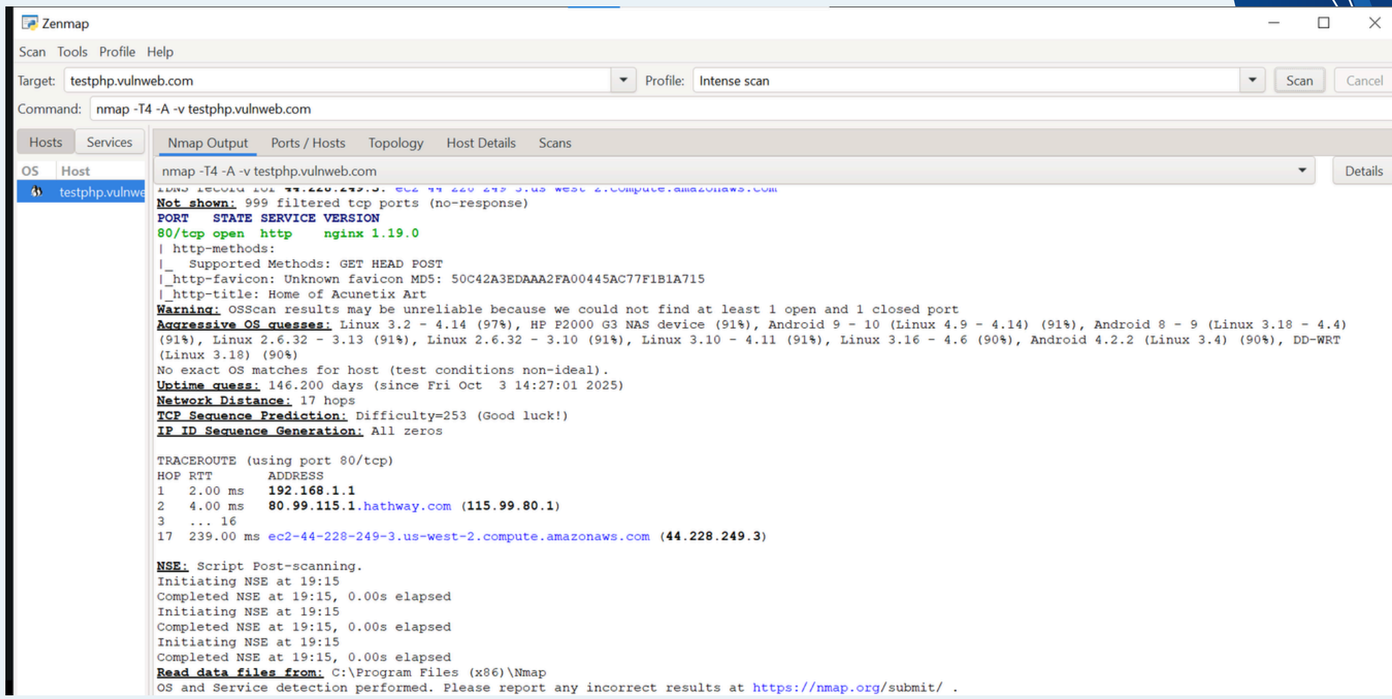
Download from: https://nmap.org

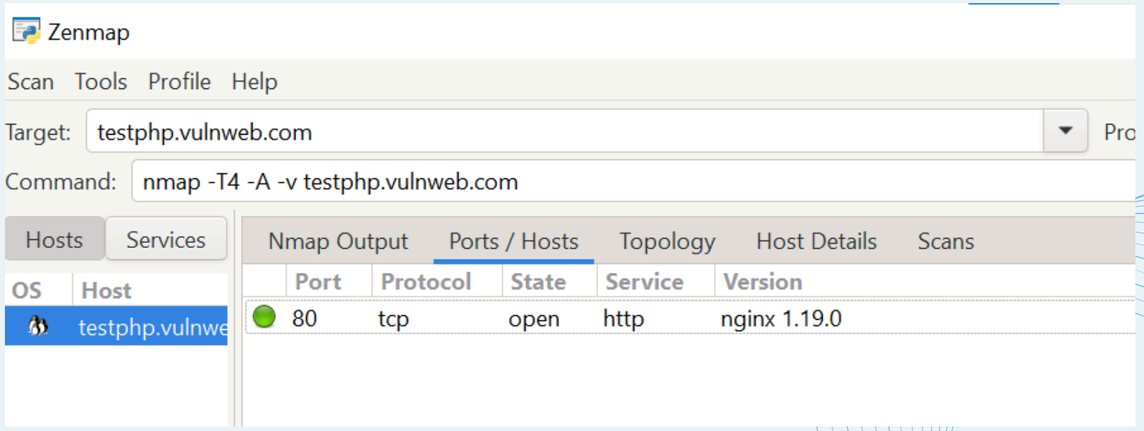
Basic Scan Command:

nmap -sV -T4 targetwebsite.com

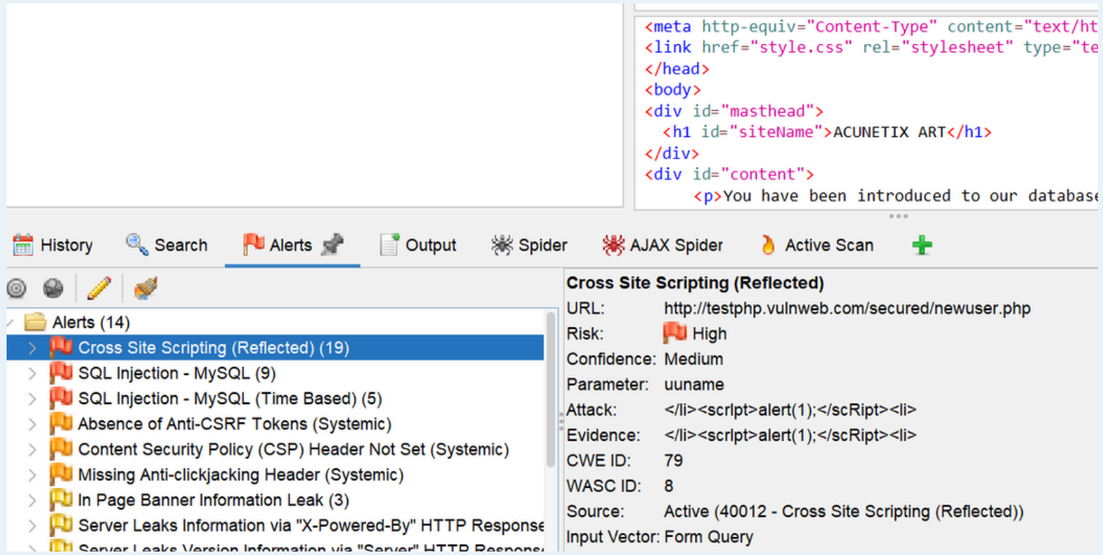
What to look for:

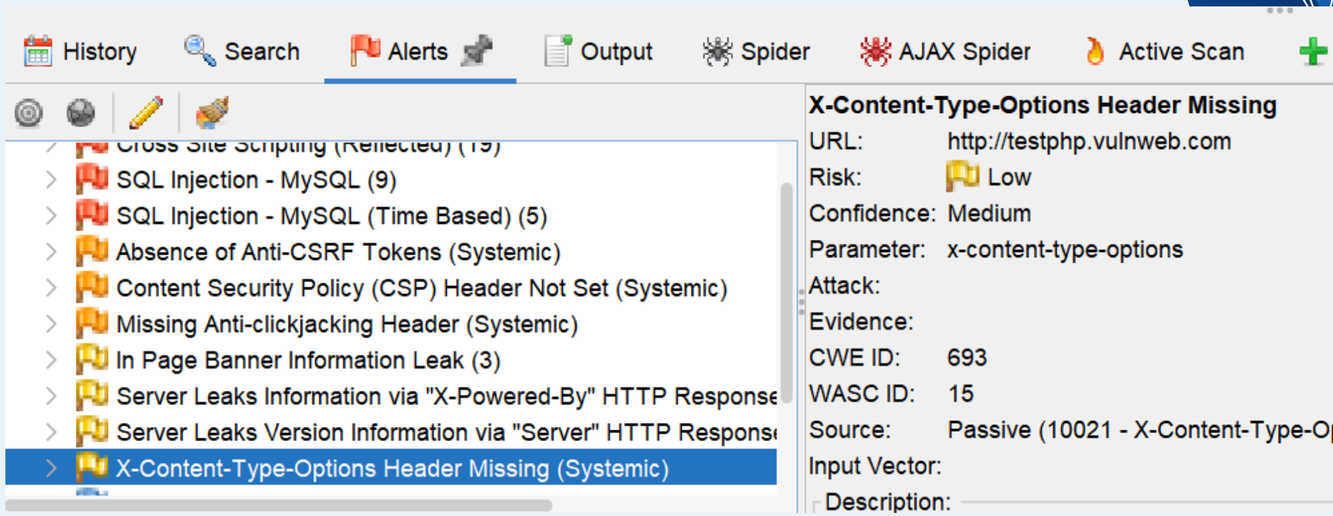
- Open ports (80, 443, 21, etc.)
- Service versions (Apache, Nginx, MySQL)
- Outdated versions

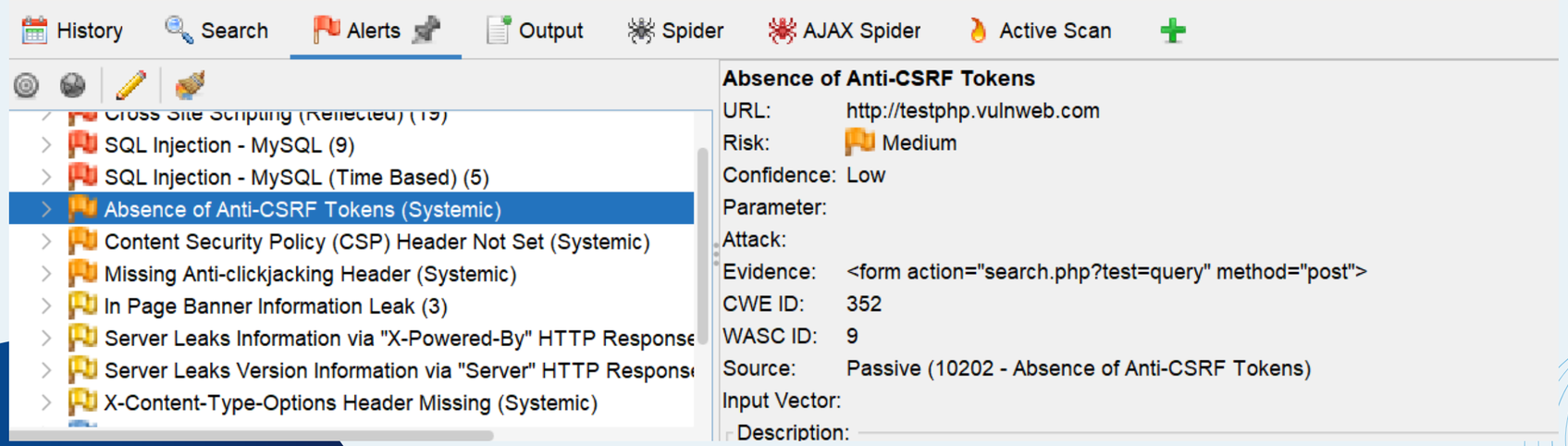




SCAN USING OWASP ZAP (PASSIVE SCAN)







FINDINGS & RISK ANALYSIS USING DEVOLOPER TOOLS

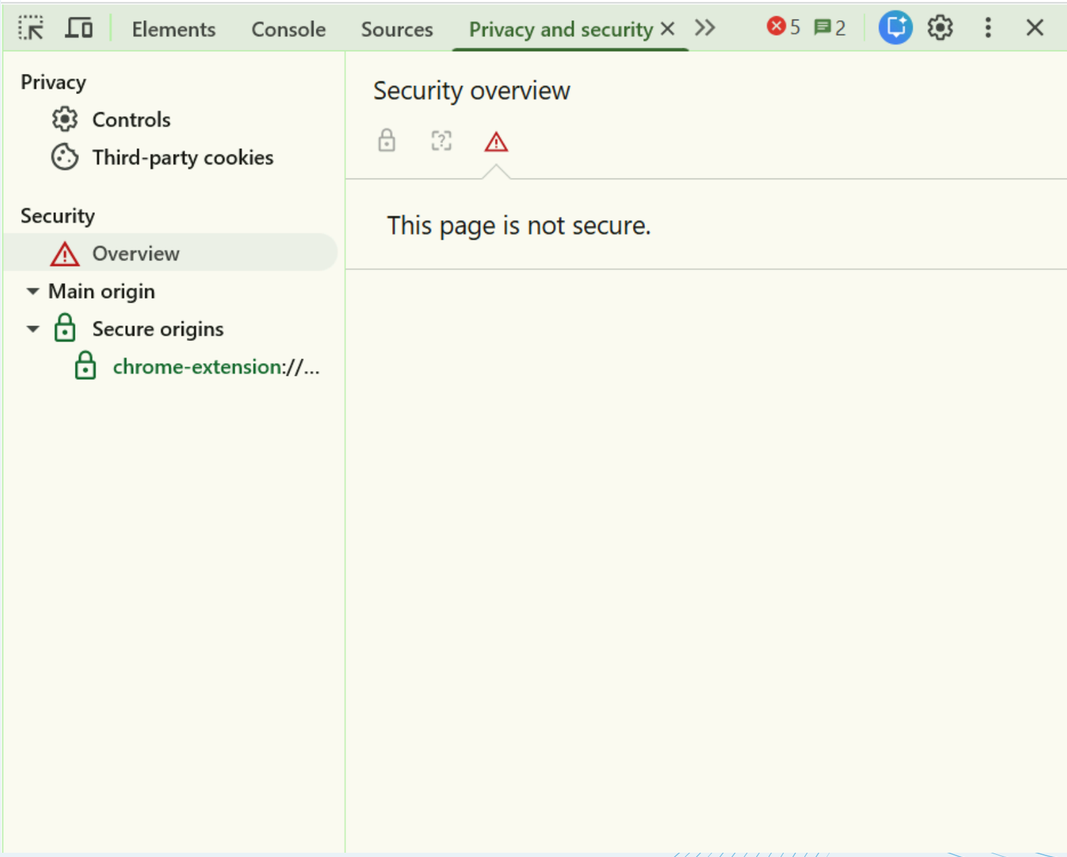
Finding 1: Website Not Using HTTPS

Description:

The website communicates over HTTP (Port 80) without SSL/TLS encryption.

Evidence:

Security tab shows: “This page is not secure.”



Risk Level: HIGH

Impact:

- Data transmitted in plain text
- Vulnerable to Man-in-the-Middle (MITM) attacks
- Session hijacking possible

FINDING 2: OUTDATED PHP VERSION (PHP 5.6.40)

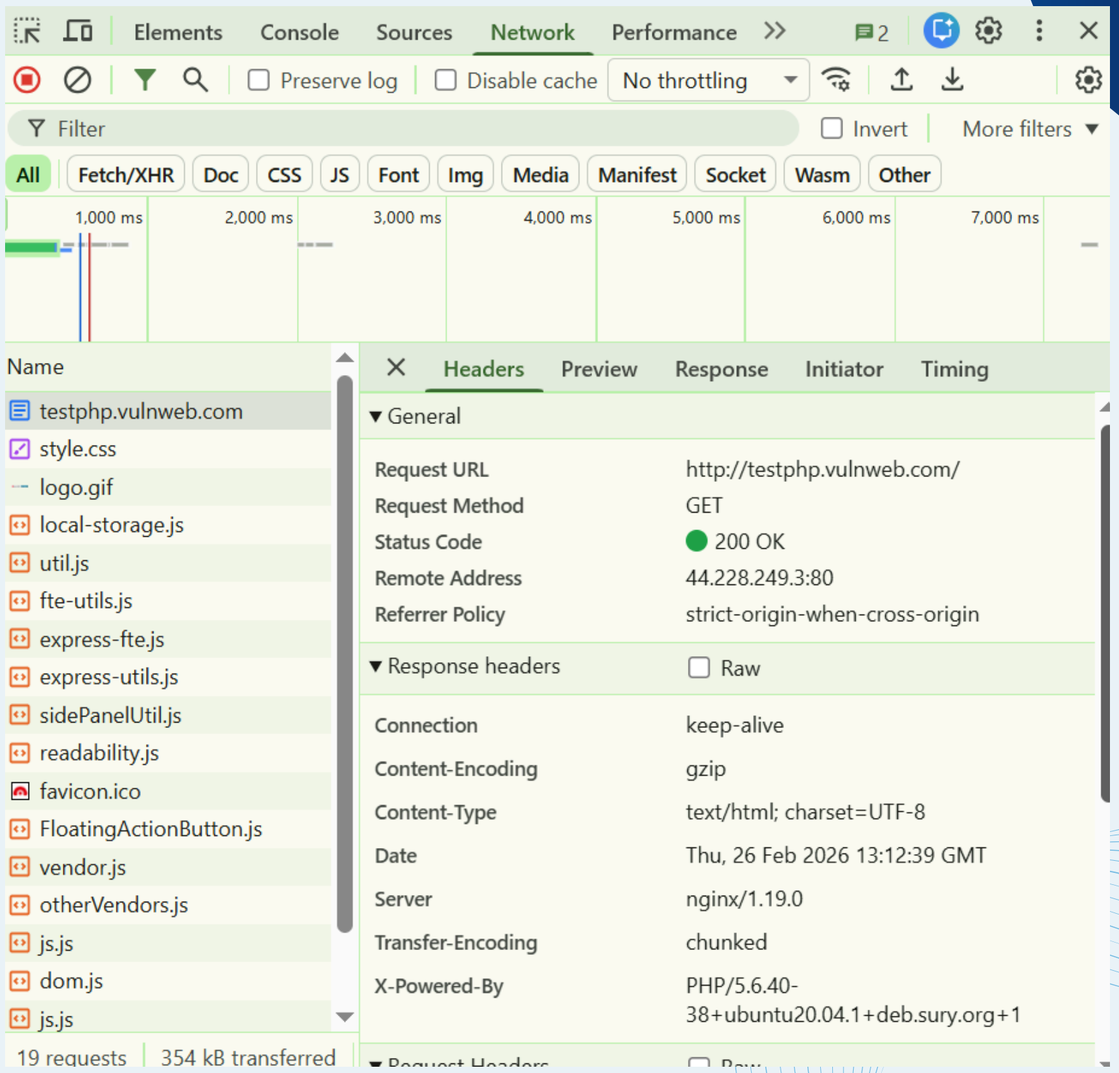
- PHP 5.6 is end-of-life and no longer receives security updates.
- Risk Level: **HIGH**

Impact:

- Known vulnerabilities exploitable
- Increased risk of remote code execution

Recommendation:

- Upgrade to PHP 8.x
- Disable X-Powered-By header



FINDING 3: INSECURE COOKIE CONFIGURATION

Observed cookie:

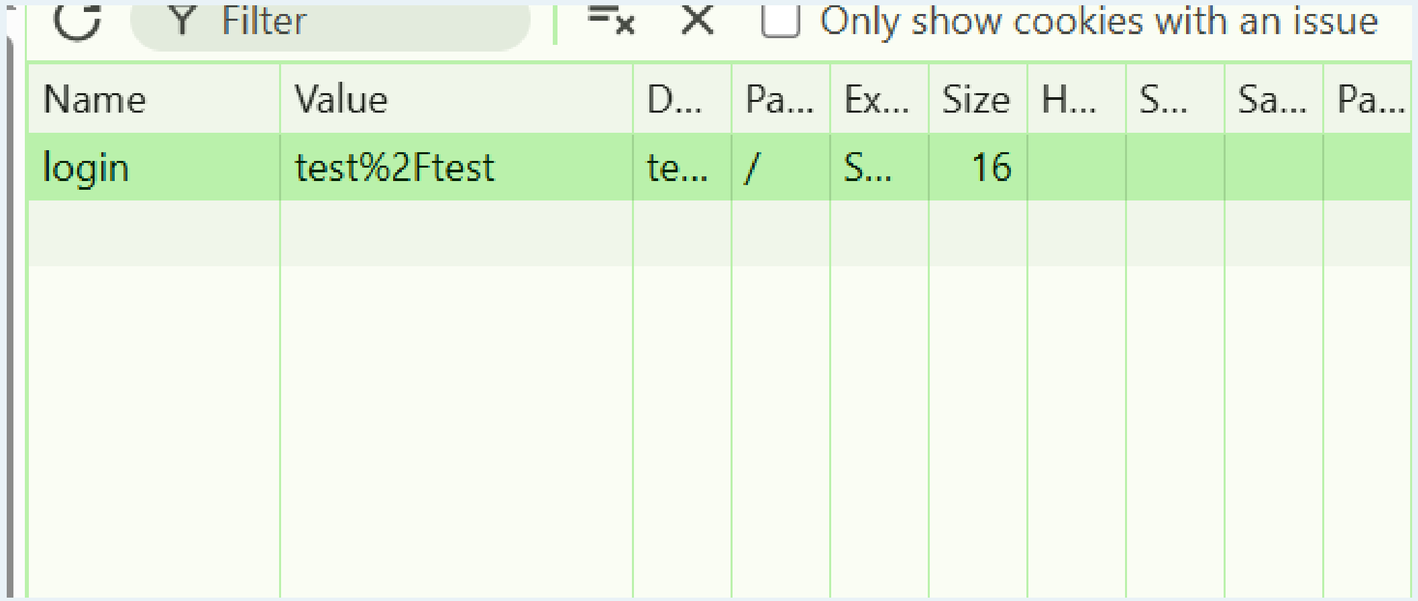
- Name: login
- Value: test%2Ftest

<u>Issues identified:</u>

- Secure flag not enabled
- HttpOnly flag not enabled
- Sensitive data stored in cookie
- Risk Level: **HIGH**

<u>Impact:</u>

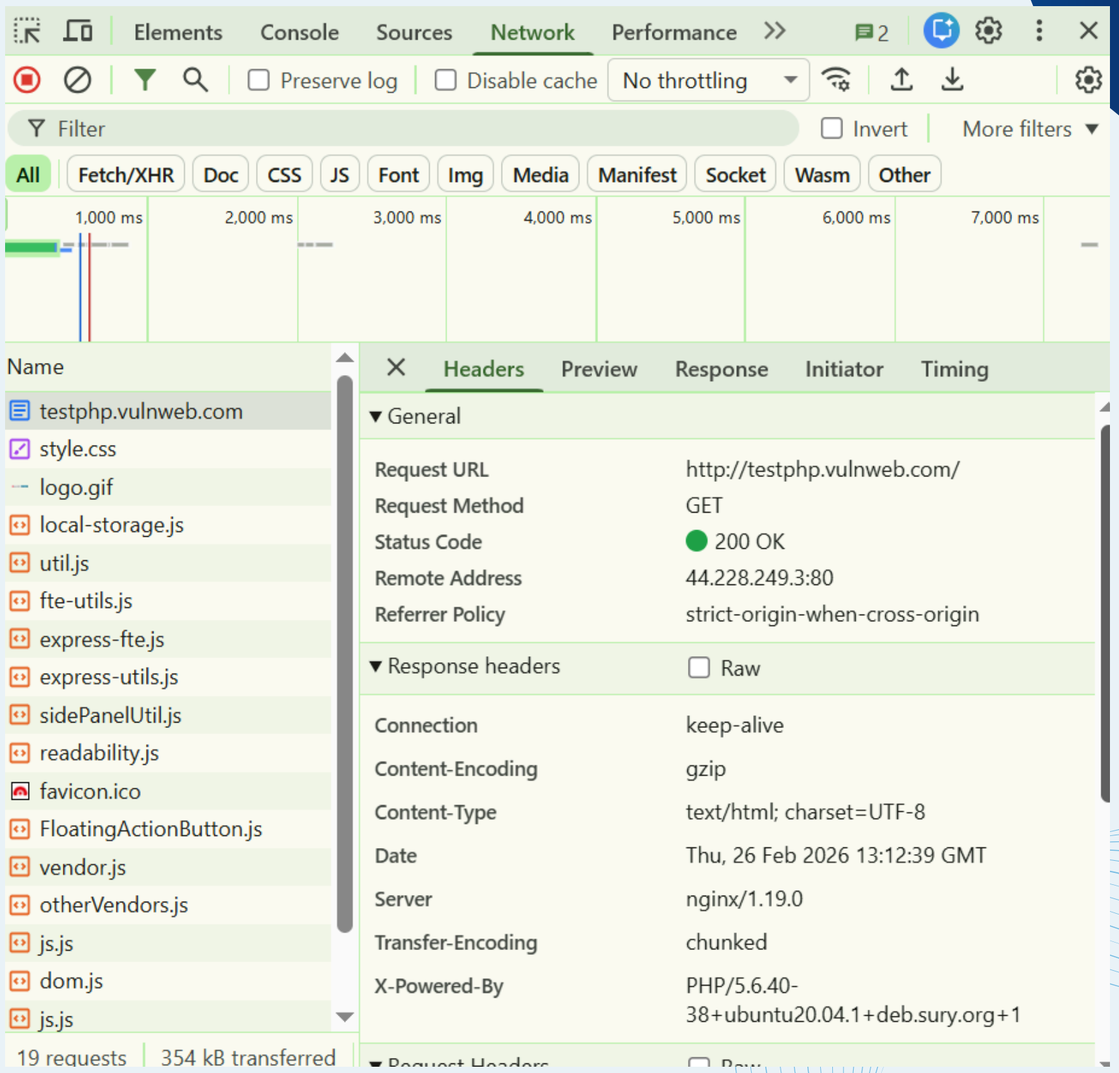
- Cookie theft via XSS
- Credentials exposure
- Session hijacking



Name	Value	D...	Pa...	Ex...	Size	H...	S...	Sa...	Pa...
login	test%2Ftest	te...	/	S...	16				

FINDING 4: SERVER VERSION DISCLOSURE

- The server is revealing its exact version.
- Risk Level: **Medium**
- Why Risky: Attackers can search for known vulnerabilities in nginx 1.19.0
- Recommendation: Disable version disclosure in nginx:



RISK CLASSIFICATION CRITERIA

Vulnerability	Risk	Impact
Outdated PHP 5.6	High	Known exploits
Server version disclosure	Medium	Information leakage
No HTTPS	High	Data interception
Missing security headers	Medium	XSS / Clickjacking

REMEDIATION PLAN

Priority	Action
Immediate	Enable HTTPS
Immediate	Upgrade PHP
High	Secure cookies properly
Medium	Hide server version
Medium	Implement security headers

CONCLUSION

- The security assessment identified several critical vulnerabilities, particularly the absence of HTTPS encryption and the use of outdated server technologies.

- These weaknesses significantly increase the risk of data interception, session hijacking, and exploitation of known vulnerabilities.

- Immediate remediation is strongly recommended to enhance the website’s security posture